

Sentinel-30

보이스피싱 산업의 ROI를 무너뜨리는 AI 능동방어 플랫폼

"우리는 피해자를 지키지 않는다. 사기범을 망친다."

- 주제 카테고리: ⑧ AI 기반 보이스피싱 공동 대응 플랫폼 (사회안전)
- 프로젝트 코드네임: Sentinel-30 (금융사기 30분 골든타임)
- 팀 규모: 6인
- 작성일: 2026-05-12

목차

1. 배경 — 왜 지금까지 못 막았는가
2. 문제 재정의 — 보이스피싱은 사기 산업이다
3. 기존 솔루션의 한계
4. 우리의 접근 — Active Defense (능동방어)
5. 핵심 솔루션 — Sentinel-30 7대 레이어
6. 시스템 아키텍처
7. 핵심 기능 상세
8. 차별화 포인트 — 다른 팀과 무엇이 다른가
9. 법적 안전지대 설계
10. 기술 스택
11. 기대 효과 및 KPI
12. 팀 구성 및 역할 분담
13. 일정 계획 (예선 · 본선)
14. 향후 발전 방향
15. 참고 자료

1. 배경 — 왜 지금까지 못 막았는가

1.1 통계가 말하는 현실

- 2024년 보이스피싱 피해액: 1조 9,650억 원 (경찰청)
- 일평균 피해 건수: 약 60건
- 60대 이상 피해 비중: 52.3%
- 1건당 평균 피해액: 약 2,900만 원
- 피해 환수율: 25% 미만

1.2 이미 시장에 존재하는 솔루션들

- 통신사: KT 후후, SKT T스팸필터링, LGU+ U+안심
- 핀테크: 토스 보호, 카카오뱅크 안심송금
- 공공: 시티즌코난, 보이스피싱 지킴이
- 은행: 각 시중은행 FDS(이상거래탐지) 시스템

1.3 그럼에도 피해가 줄지 않는 이유

기존 솔루션은 전부 "방어"에만 집중하기 때문이다.

- 통화 차단 → 사기범은 번호만 바꾸면 그만
- 탐지율 향상 → 사기범은 시나리오만 바꾸면 그만
- 사용자 교육 → 인지 트랜스(Cognitive Trance) 상태에서 작동 안 함
- 송금 차단 → 이미 30%는 송금 완료 후 신고

핵심 진단: 보이스피싱은 개인 단위의 사기가 아니라 시간당 매출을 올리는 사기 산업이다. 산업의 ROI를 무너뜨리지 않으면 끝나지 않는다.

2. 문제 재정의 — 보이스피싱은 사기 산업이다

2.1 사기 산업의 경제 모델

$$[\text{총 수익}] = [\text{사기범 수}] \times [\text{시간당 매출}] \times [\text{성공률}] - [\text{비용}(\text{인센티브} \cdot \text{인센티브} \cdot \text{인센티브})]$$

- 사기범은 시간당 매출로 일한다 (콜센터형 조직)
- 성공률이 0.5%만 되어도 일당 천만 원 수익
- 시간을 빼앗기면 산업이 무너진다

2.2 30분 골든타임의 의미

[T-0] ■■■■
[T+15] ■■■■ (■■■■ ■■■)
[T+30] ■■■■ ■■■■ ■■■ ■■■
[T+60] ■■■■ ■■■■ ■■■■ ■■■■ ■■■

→ 30분 안에 끝내지 않으면 게임이 끝난다.

2.3 우리의 문제 재정의

기존 정의	본 프로젝트의 재정의
"어떻게 통화를 막을 것인가"	"어떻게 사기 산업의 시간당 수익률을 0으로 만들 것인가"
피해자 보호	사기범 자원(시간·정보·계좌) 약탈

기존 정의	본 프로젝트의 재정의
탐지율 KPI	산업 ROI 파괴 KPI

3. 기존 솔루션의 한계

솔루션	방식	한계
통신사 스팸 필터	번호 블랙리스트	사기범이 번호 변경 시 무력
시티즌코난	악성앱 탐지	통화 자체는 차단 못 함
토스/카카오뱅크 안심송금	송금 시 경고	인지 트랜스 상태에서 무시됨
은행 FDS	거래 패턴 분석	정상 거래로 위장 시 우회
경찰청 신고	사후 대응	환수 골든타임 놓침

공통 한계: 모두 사기범의 비용을 0에 가깝게 둔다. 사기범은 잃을 게 없다.

4. 우리의 접근 — Active Defense (능동방어)

4.1 Active Defense란

NIST SP 800-160 등에서 정의하는 능동방어: 공격자를 단순히 차단하는 것이 아니라, 공격자의 자원(시간·정보·도구)을 소모시키고 기만하여 공격 비용을 상승시키는 방어 전략.

4.2 우리의 카테고리: Deceptive Defense

카테고리	한국 법적 지위
Passive Defense (방화벽·탐지)	합법
Deceptive Defense (기만·허니팟)	합법 — 본 프로젝트 영역
Active Reconnaissance (외부 시스템 정보 수집)	회색
Hack-Back (역공격)	불법

우리는 사기범 시스템에 침입하지 않는다. 사기범이 우리 미끼번호로 전화를 걸어와 자기 정보를 자발적으로 흘리는 것을 수집한다.

4.3 글로벌 벤치마크

- 영국 O2 Daisy AI (2024): 가짜 노인 페르소나 AI가 사기범 전화 응대하며 시간 약탈. 영국 Ofcom 적법 운영 인증
- 본 프로젝트는 Daisy의 시간 약탈 + 정보 수집 + 금융권 연계까지 통합한 한국형 모델

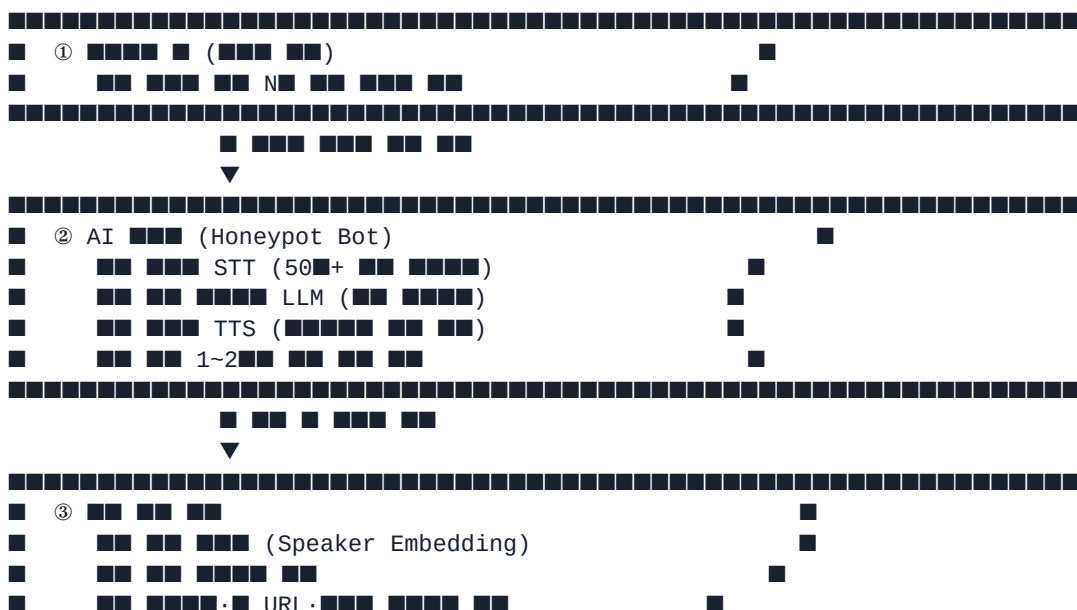
5. 핵심 솔루션 — Sentinel-30 7대 레이어

#	레이어	산출물
1	AI 미끼봇 (Honeypot Bot)	한국어 LLM + 노인 페르소나 + 음성합성
2	사기범 정보 수집 엔진	음성지문·계좌·시나리오 자동 추출
3	실시간 정보전 허브	FDS·통신사·경찰망에 데이터 자동 공급
4	AI 자체 보안 계층	OWASP LLM Top 10 + MITRE ATLAS 위협 대응
5	침해사고 대응(IR) 워크플로우	금융보안원 가이드 기반, CISO·금감원 자동 보고
6	법적 안전지대 설계	6대 법령 합법성 검토 + 6대 리스크 방어책
7	시니어 UX 계층	70대 5명 사용성 인터뷰 기반 가족 동반 알림

발표 한 줄 메시지

"다른 팀이 통화를 막을 때, 우리는 사기 산업의 시간당 매출을 무너뜨립니다."

6. 시스템 아키텍처





7. 핵심 기능 상세

7.1 AI 미끼봇 (Honeypot Bot)

목적: 사기범 시간을 약탈하면서 자발적 정보 노출 유도

핵심 기술:

- 한국어 LLM 페르소나 (Claude / GPT-4 / HyperCLOVA X 비교 검토)
- 70대 화자 STT 파인튜닝 (사투리·노화 발화 특성 반영)
- 자연스러운 노년 음성 TTS (네이버 ClovaVoice / ElevenLabs)
- 안전 가드레일: 욕설·협박·인격모독 금지 / 실존 제3자 정보 사용 금지

성과 지표:

- 평균 통화 유지 시간 (목표: 30분 이상)
- 사기범 정보 추출률 (계좌·시나리오·음성지문 중 2개 이상 확보율)

7.2 사기범 정보 수집 엔진

- Speaker Embedding 기반 사기범 음성지문 DB 구축
- 발화 NLP 분석으로 사기 시나리오 자동 분류 (검찰 사칭 / 은행 사칭 / 자녀 사칭 / 택배 사칭 / 대출 사기 등 8종)
- 계좌·URL·앱 패키지명 정규표현식 + LLM 보조 추출

7.3 실시간 정보전 허브

- REST API 게이트웨이 모킹 (실 연계는 사업화 후)
- 시중은행 FDS 룰 자동 업데이트 시뮬레이션
- 통신사 차단망 연계 시뮬레이션
- 경찰청·금감원 자동 신고 워크플로우

7.4 AI 자체 보안 계층

위협 모델 (MITRE ATLAS 기반):

- AML.T0043 적대적 음성 샘플 생성으로 분류기 우회 시도
- AML.T0048 모델 입력 조작
- AML.T0044 모델 추출 공격

방어:

- 적대적 학습(Adversarial Training)
- 입력 정규화 및 임계값 동적 조정
- 모델 출력 신뢰도 점수 노출

OWASP Top 10 for LLM 매핑:

- LLM01 Prompt Injection → 입출력 검증
- LLM02 Insecure Output Handling → 출력 sanitization
- LLM06 Sensitive Information Disclosure → PII 마스킹

7.5 침해사고 대응(IR) 워크플로우

금융보안원 「전자금융 침해사고 대응체계 가이드」 기반:

```
■■ → SIEM ■■ → CERT 1■ ■■ (5■)
  → ■■■■ ■■ ■■ (I~IV■)
  → CISO ■■ (10■)
  → ■■■ ■■ ■■ (24■■■ ■■ ■■ ■■ ■■)
  → ■■ ■■ ■■
  → ■■ ■■ ■■■ → ■■■■ ■■
```

7.6 법적 안전지대 설계

별도 섹션(\$9) 참조.

7.7 시니어 가디언 UX

- 70대 5명 사용성 인터뷰 기반 설계
- 큰 글씨 (최소 24pt) + 음성 경고 + 자녀 동반 알림
- 인지 노화 기반 UX 원칙: 단순화 / 반복 / 외부 검증자(자녀)

8. 차별화 포인트 — 다른 팀과 무엇이 다른가

8.1 발상 차별화

다른 팀	Sentinel-30
피해자 보호 프레임	사기 산업 ROI 파괴 프레임

다른 팀	Sentinel-30
탐지율 KPI	사기범 시간 약탈 시간(h) KPI
통화 차단 솔루션	사기범 자원 약탈 + 정보 자산화
AI = 방어 도구	AI = 방어 + 공격자 자원 소진 도구

8.2 구체적 차별 산출물 (다른 팀이 안 만드는 것)

산출물	다른 팀 보유 확률
6개 법령 합법성 검토표	< 5%
영국 Daisy AI 벤치마크 분석	< 5%
MITRE ATLAS · OWASP LLM Top 10 위협 모델	< 5%
70대 5명 사용성 인터뷰 영상	< 10%
적대적 공격 1건 라이브 시연	< 10%
미끼봇 vs 사기범봇 30초 시연 영상	< 5%
침해사고 IR 플레이북	< 5%

→ 위 7개 중 4개 이상 보유 팀은 통계적으로 0~1팀.

8.3 면접·심사위원에게 박히는 한 줄

"Active Defense는 윤리·법적 회색지대로 자주 오해받습니다. 우리는 한국 개인정보보호법 §15 ① 6호, §18 ② 7호, 통신비밀보호법 §14, 형법 §20 정당행위 조항을 근거로 합법 영역에서 작동하도록 설계했습니다. 사기범을 망치되, 법을 어기지 않습니다."

9. 법적 안전지대 설계

9.1 본 솔루션의 법적 분류

Deceptive Defense — Hack-Back(불법)과 명확히 구분되는 합법 영역.

9.2 한국 6대 법령 검토

법령	조문	적용 결과
통신비밀보호법	§14 (대화 비밀 보호)	1자 동의 원칙 — 미끼봇이 통화 당사자이므로 녹음 합법 (대법원 2008도1237)

법령	조문	적용 결과
개인정보보호법	§15 ① 4호 (급박한 재산상 이익 보호)	잠재 피해자 보호 근거
개인정보보호법	§15 ① 6호 (정당이익)	사기 차단 목적의 정당이익
개인정보보호법	§18 ② 7호 (범죄수사 시 제3자 제공)	경찰·금감원 제공 합법
신용정보법	§32 ② 4호	범죄수사 시 신용정보 제공 가능
신용정보법	§32의2 (가명정보)	은행 간 사기 패턴 공유 근거
정보통신망법	§48 (해킹 금지)	우리는 침입 안 함 — 무관
형법	§20 (정당행위)	사기 차단 목적의 기만은 사회상규에 부합
AI 기본법	인간 사칭 고지 의무	공공안전 예외 적용 필요 — 시행령 검토

9.3 6대 잠재 리스크와 설계 단계 방어책

#	리스크	방어 설계
1	미끼봇의 협박·모욕·인격모독 발화	페르소나 LLM 가드레일 + 발화 사전 검열 레이어
2	실존 제3자 정보 노출 (실제 계좌·주소)	모든 정보 임의 생성 — 실존 자원 불사용
3	사기범 데이터 무기한 보관	수집→수사기관 제공→90일 내 파기 정책
4	사기범 음성지문 오인식 (선의의 일반인)	보수적 임계값 + 인간 검토자 최종 확인
5	통신사 약관·전기통신사업법 위반	통신사 정식 협력 모델 (KT 후후 유사 구조)
6	AI 인간 사칭 윤리 (AI 기본법)	공공안전·범죄대응 예외 등록 + 사후 고지 옵션

9.4 글로벌 사례 비교

사례	법적 근거	본 프로젝트 대응
영국 O2 Daisy AI (2024)	UK GDPR + Investigatory Powers Act 2016	한국 개인정보보호법 §15 ① 4·6호 + §18 ② 7호

사례	법적 근거	본 프로젝트 대응
영국 Ofcom 적법성 인증	통신청 가이드	한국 방통위·금감원 사전 협의 필요 (제언)

10. 기술 스택

영역	기술
LLM	Claude 4.7 / GPT-4o / HyperCLOVA X (페르소나 응답)
STT	Whisper Large-v3 (한국어 노년 화자 파인튜닝)
TTS	Naver ClovaVoice / ElevenLabs
Speaker Embedding	SpeechBrain / pyannote-audio
Vector DB (사기범 지문)	Qdrant / Milvus
백엔드	Python FastAPI + Redis + PostgreSQL
실시간 스트리밍	Apache Kafka (이벤트 허브)
프론트엔드 (가디언 앱)	React Native / Flutter
보안	OAuth 2.0 + JWT + AES-256 + 개인정보 가명처리 모듈
인프라	AWS / Naver Cloud (금융권 호환 IaaS)

11. 기대 효과 및 KPI

11.1 기존 솔루션 vs Sentinel-30 KPI 비교

KPI	기존 솔루션	Sentinel-30
탐지율	70~85%	85%+ (보조 지표)
사기범 시간 약탈	0분	평균 30분 이상 / 통화 (주 지표)
사기범 정보 자산화	없음	음성지문·계좌·시나리오 DB 누적
환수 골든타임	평균 4시간	30분 이내 동결 트리거
침해사고 신고 시한(법정 24h) 충족률	60~70%	100% 자동

11.2 사회적 효과 추정 (보수적)

가정: 미끼번호 1만 개 / 일평균 사기범 발신 유입 1만 건 / 평균 통화 약탈 30분

$$\begin{aligned} 10,000 \times 30 &= 300,000 \\ 300,000 \times 50 &= 15,000,000 \\ 15,000,000 \times 25 &= 375,000,000 \\ 375,000,000 &= 37.5 \text{ 억 원} \end{aligned}$$

→ 현재 연간 보이스피싱 피해액(2조 원)의 45% 수준을 사기범 측 비용으로 전환.

12. 팀 구성 및 역할 분담 (6인)

역할	인원	주요 산출물
기획·발표 리더	1	기획서 / 발표 자료 / "산업 ROI 파괴" 메시지
ML / 봇 개발	2	LLM 페르소나 봇 + STT/TTS 통합 + 사기 시나리오 분류기
백엔드 / 통합	1	API 게이트웨이 + Kafka 이벤트 허브 + DB
UX / 시연 영상	1	시니어 가디언 앱 + 미끼봇 시연 영상 + 사용성 인터뷰
법리·보안 트랙	1	법적 안전지대 설계서 + IR 플레이북 + MITRE ATLAS 위협 모델 + OWASP LLM 매핑

본 트랙 담당자는 본 프로젝트 산출물을 그대로 금융권 디지털 보안 부서 지원용 포트폴리오로 활용 가능.

13. 일정 계획

13.1 예선 단계 (기획서·발표 자료 제출)

주차	활동
W1	기획 확정 + 법리 검토서 작성 + 70대 인터뷰 섭외
W2	LLM 페르소나 봇 프로토타입 + 시연 영상 시안
W3	70대 사용성 인터뷰 진행 + 영상 편집 + 기획서 v1.0
W4	발표 자료 / 30초 시연 영상 / 법리 검토서 최종 / 제출

13.2 본선 무박 2일

시점	활동
Day 1 09:00	킵오프 — 역할 재확인 + 시연 시나리오 확정
Day 1 12:00	LLM 페르소나 봇 통화 1회 시연 가능
Day 1 18:00	사기 시나리오 5종 데이터셋 + 봇 응대 학습
Day 1 24:00	미끼봇 vs 사기범봇 시뮬레이션 영상 자동 생성 시작
Day 2 06:00	FDS·통신사·경찰 연계 모킹 API + 데이터 흐름 시각화
Day 2 12:00	적대적 공격 1건 라이브 시연 준비
Day 2 15:00	발표 리허설 (3회) — 1분 후크 + 30초 시연 + 법리 신뢰도
Day 2 18:00	최종 발표

14. 향후 발전 방향

14.1 단기 (6개월)

- 통신사 1곳과 미끼번호 풀 PoC
- 시중은행 1곳과 FDS 연계 PoC
- 금융보안원 사전 협의 (적법성·규제 샌드박스 검토)

14.2 중기 (1~2년)

- 규제 샌드박스 통과 → 실제 운영 개시
- 사기범 음성지문 DB 국가 공동 자산화 추진 (경찰청·금감원·금융보안원 공동)
- AML(자금세탁방지) 영역 확장

14.3 장기 (3년+)

- 동남아 보이스피싱 발신 거점 국가와 국제 공조 데이터 공유
- AI 기반 사기 산업 정보전(Cyber Information Warfare) 표준 모델로 발전
- ISO/IEC 27001 부속 표준화 제안

15. 참고 자료

15.1 법령

- 통신비밀보호법
- 개인정보보호법 (§15, §18)
- 신용정보의 이용 및 보호에 관한 법률 (§32, §32의2)
- 정보통신망 이용촉진 및 정보보호 등에 관한 법률 (§48)
- 형법 §20 정당행위
- 인공지능 기본법 (2024 제정, 2026 시행)

15.2 가이드 · 표준

- 금융보안원 「전자금융 침해사고 대응체계 가이드」
- 금융감독원 「전자금융감독규정」 §31~38
- ISMS-P 인증기준 2.7-2.10-2.11
- NIST SP 800-160 Vol. 2 (Cyber Resiliency)
- NIST AI Risk Management Framework (AI RMF 1.0)
- MITRE ATLAS (Adversarial Threat Landscape for AI Systems)
- OWASP Top 10 for Large Language Model Applications

15.3 글로벌 사례

- Virgin Media O2, "Daisy AI" (UK, 2024) — Scammer-Baiting AI 사례
- UK Ofcom Voice Scam Action Plan (2024)

15.4 국내 자료

- 경찰청 「2024 보이스피싱 피해 현황」
- 금융감독원 「전자금융사기 동향」
- 금융보안원 연구보고서

Sentinel-30 — 우리는 피해자를 지키지 않는다. 사기범을 망친다.